would be able to design an API that achieved its security goals against any threat. But the world is not perfect, and it is rarely possible or economical to prevent all attacks. In some environments some threats are just not worth worrying about. For instance, an API for recording race times for a local cycling club probably doesn't often need to worry about the attentions of a nation-state intelligence agency, while it may want to prevent riders trying to "improve" their own best times or alter those of other cyclists. By considering realistic threats to your API you can decide where to concentrate your efforts and identify gaps in your defenses.

The set of threats that you consider relevant to your API is known as your *threat model*, and the process of identifying them is known as *threat modeling*.

> **DEFINITION** ***Threat modeling*** is the process of systematically identifying threats to a software system so that they can be recorded, tracked, and mitigated.

There is a famous quote attributed to Dwight D. Eisenhower:

> "Plans are worthless, but planning is everything."

It is often like that with threat modeling. It is less important exactly how you do threat modeling, or where you record the results. What matters is that you do it, as the process of thinking about threats and weaknesses in your system will almost always improve the security of the API.

There are many ways to do threat modeling, but the general process is as follows: